



Network Segmentation Effectiveness for PCI DSS Scope Reduction

Prepared by : Mr. THY Dayuth

Academic Advisor : Mr. MEAS Sothearath

Company Supervisor : Mr. PHOK Visal

Period : 3 Months (20 April – 20 July 2026)

Academic year : 2026 ~ 2027

CONTENTS

- | | | | |
|---|---------------------|---|--------------------------------|
| 1 | Introduction | 5 | Finding |
| 2 | Project Description | 6 | Conclusion &
Recommendation |
| 3 | Literature Review | 7 | References |
| 4 | Methodology | | |

Company Profile

ACLEDA Bank Plc.

January 19, 1993



One of Cambodia's largest
and most prominent
commercial banks



Secure, innovative, and
ethical financial services
sustainably



leading and the most
trusted commercial bank

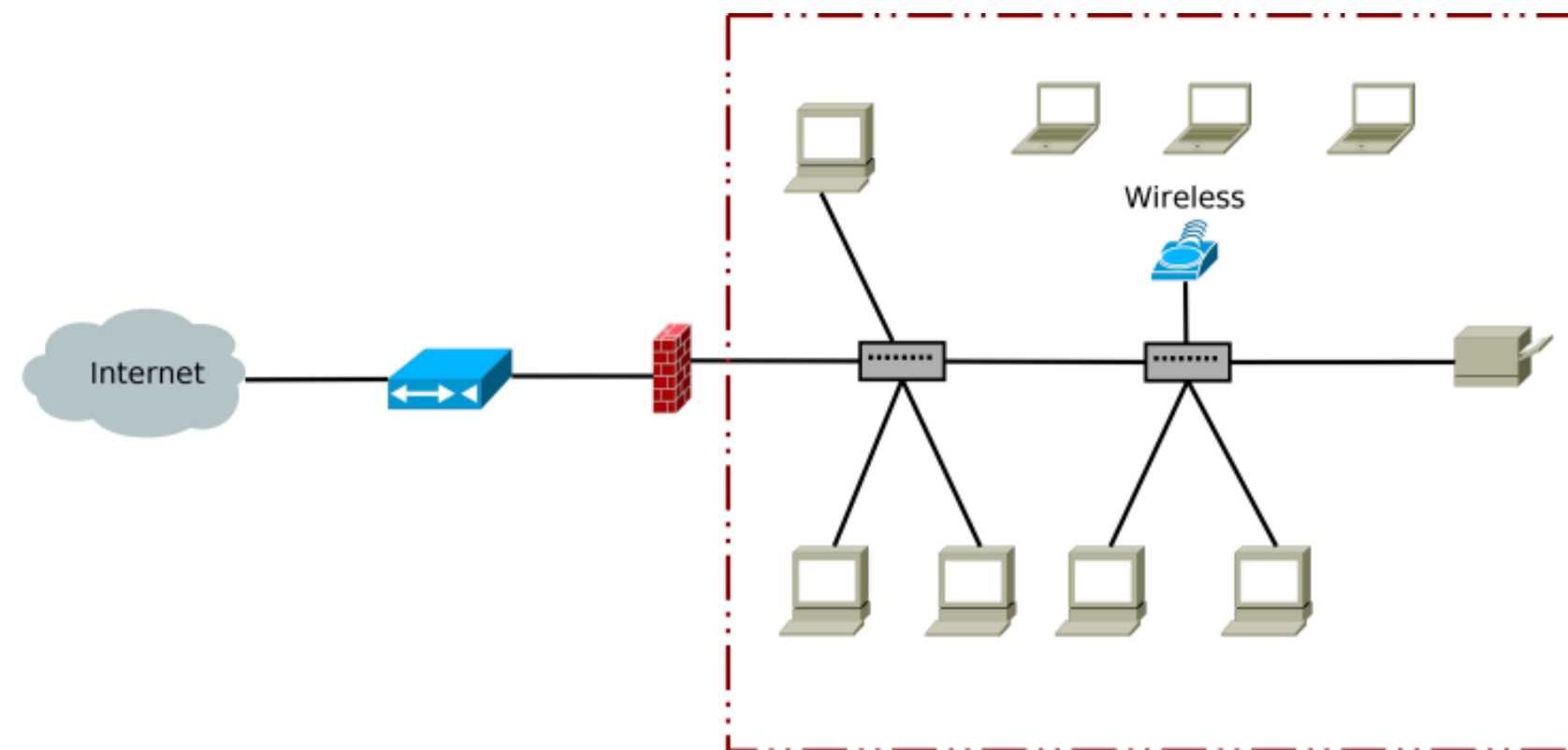


Loans, Deposits, and Money Transfers



Problem Statements

Flat Network Architecture



Flat Network Topology

- Simplicity and Ease of Deployment
- Low Operational and Hardware Costs
- Unrestricted Communication and High Throughput

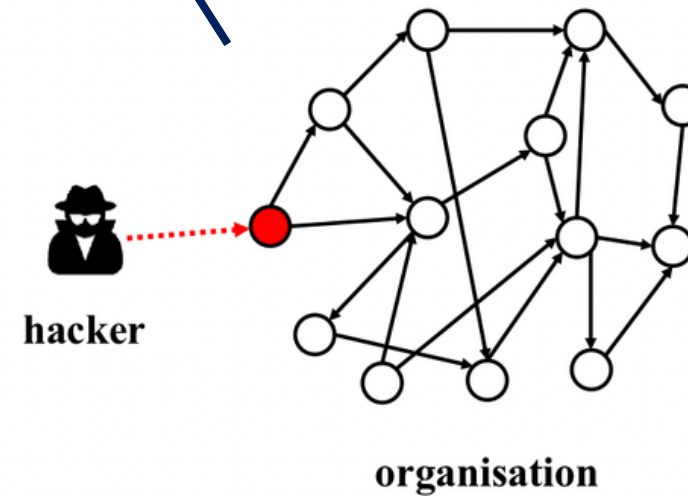
Problem Statements

Security Impact



Unauthorized Access

Operation Impact



Lateral Movement



Higher Audit Effort

Objectives



Segment the Payment Path



Protect Account Data



**Validate Control
Effectiveness**

Scope of Projects

- Docker-based PCI DSS Segmentation Lab
- Secured Transaction Path POS - CDE
- Implement Controls Aligned Security Controls
- Validate its Effectiveness and Gather Evidence

Exclude:

- Live Card Data
- Production Banking
- Formal PCI DSS

Certification

Literature Review

PCI DSS v4.0.1

No.	Control	Core Requirement
1	Build and Maintain a Secure Network and Systems	Install and maintain network security controls
2		Apply secure configurations to all system components
3	Protect Account Data	Protect stored account data
4		Protect cardholder data with strong cryptography during transmission
5	Maintain a Vulnerability Management Program	Protect systems and networks from malicious software
6		Develop and maintain secure systems and software
7	Implement Strong Access Control Measures	Restrict access by business need-to-know
8		Identify users and authenticate access
9		Restrict physical access to cardholder data
10	Regularly Monitor and Test Networks)	Log and monitor access to systems and cardholder data
11		Test security systems and processes regularly
12	Maintain an Information Security Policy	Support information security with organizational policies and programs

- 6 Controls Objectives
- 12 Principal Requirements
- 249 Detailed Requirements

Literature Review

Network Segmentation

Isolates CDE reduce PCI DSS scope when properly enforced and tested.

Least Privilege Connectivity

Allows only approved traffic and denies all other connections by default

Data Protection

Protects PAN with encryption, tokenization and prevent CVV storage.

Control Validation

Uses logs, vulnerability scans, and segmentation tests to verify controls

Technology Used



Orchestration



Retail VPN



Firewall
Enforcement



Reverse
Proxy



Payment
Processing



Cryptographic
Services



Database



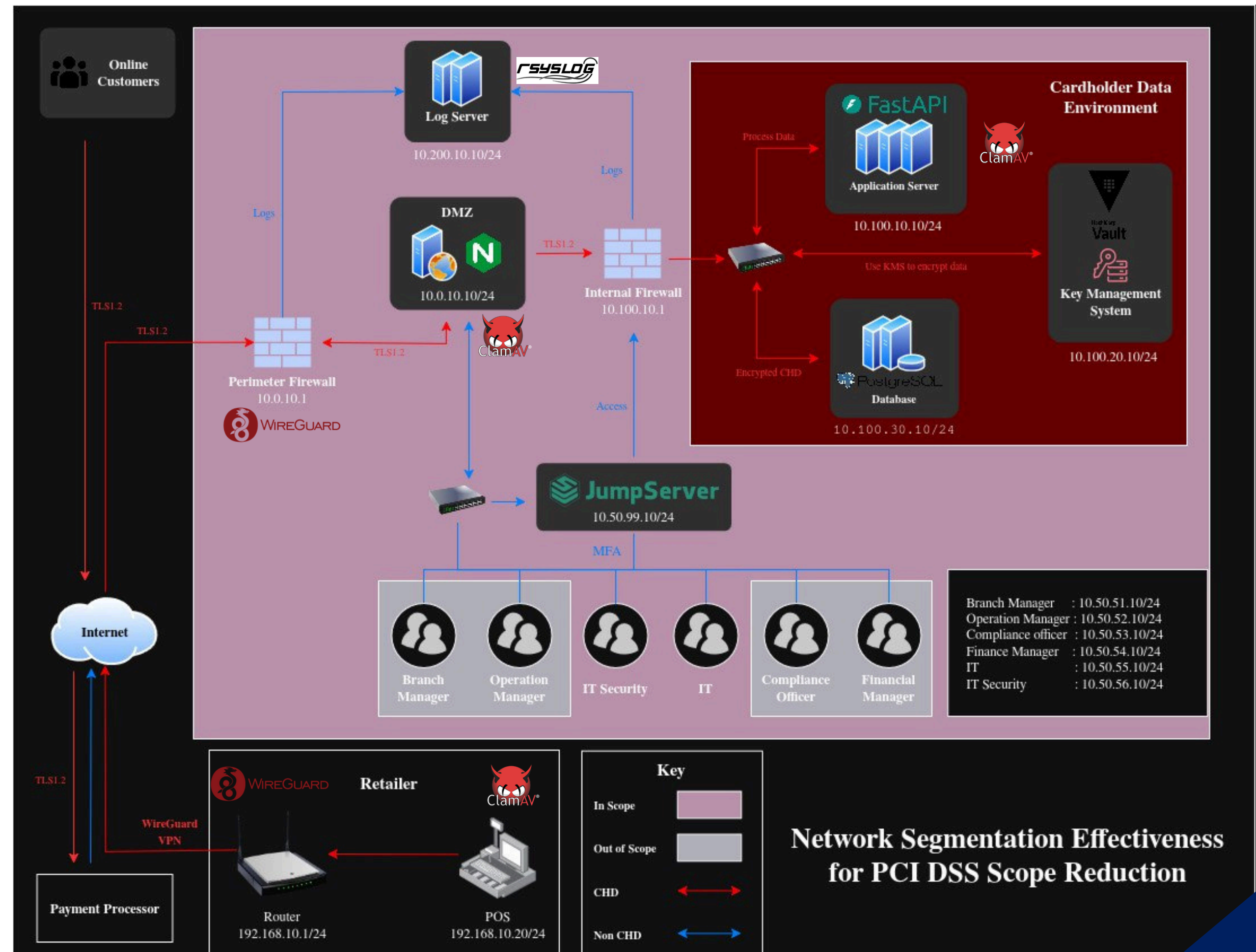
Centralized
Logging



Anti
Malware

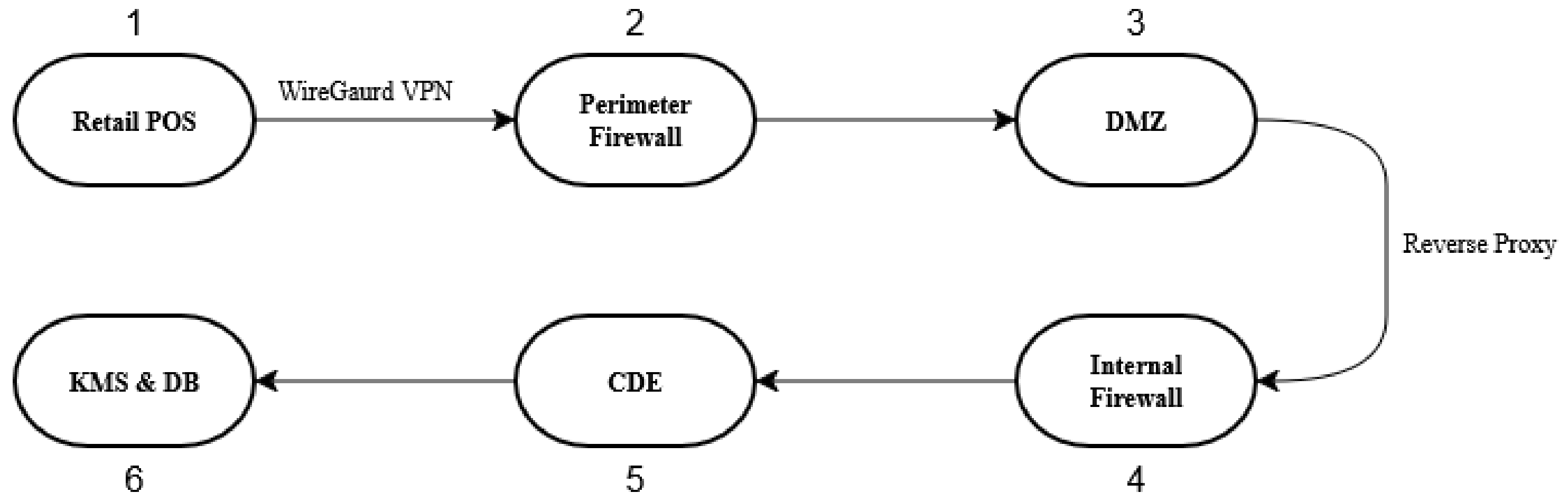
Diagram

System Diagram Overview

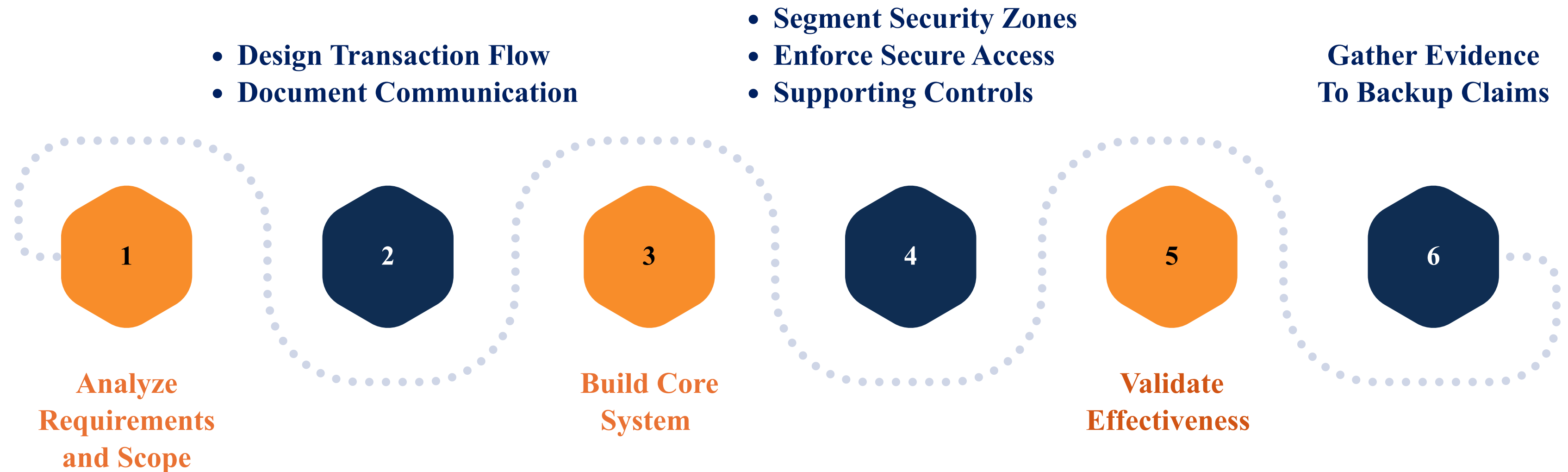


Approved Path

Transaction Which Made Outside of Define Path Be Denied



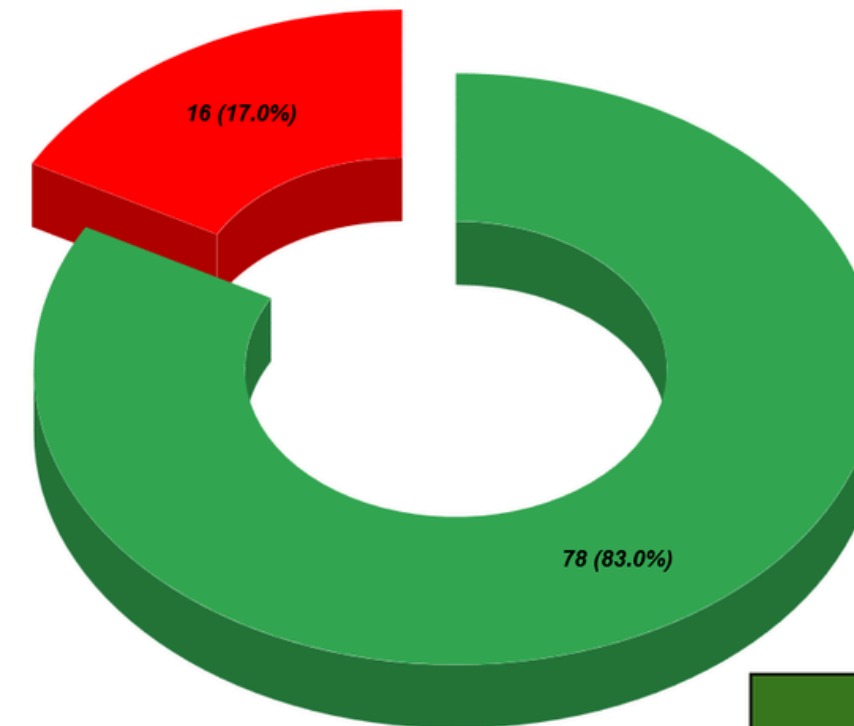
Implementation



Results

- Secured Transaction
- Any Activities are Logged as Artifacts
- Defined Zone based on Security Level
- Comply with 78 selected sub-requirements

Compliance Checklist Pie Chart



Completed	78
Pending	0
Not Applicable	16

ROLE	Name
Auditor	THY DAYUTH
Implementor	THY DAYUTH
	SOTH VANNDY
	CHO DAVON

Finding

Database Masking and Encryption with Tokenization

```
Windows PowerShell
PS D:\Workspaces\Sandbox\v6> Write-Host "`n=== PROTECTED POSTGRESQL RECORD ==="

=== PROTECTED POSTGRESQL RECORD ===
PS D:\Workspaces\Sandbox\v6> docker compose exec -T db psql -U cde_admin -d cde_db -P pager=off -c "SELECT tx_id, authorization_status, masked_pan, left(card_token,20) AS token_prefix, left(encrypted_chd,45) AS ciphertext_prefix, vault_key_version, tx_timestamp FROM transactions ORDER BY tx_id DESC LIMIT 1;"
tx_id | authorization_status | masked_pan | token_prefix | ciphertext_prefix | vault_key_version | tx_timestamp
-----+-----+-----+-----+-----+-----+-----
46 | approved | *****1111 | tok_cdfbf53fa22ffa8b | vault:v1:TOB+HFr+lZQFUVY/+naW2R40VYwTaCifudyd | 1 | 2026-07-09 19:17:09.880785+00
(1 row)

PS D:\Workspaces\Sandbox\v6>
PS D:\Workspaces\Sandbox\v6> Write-Host "`n=== SCHEMA PROOF: NO CVV FIELD ==="

=== SCHEMA PROOF: NO CVV FIELD ===
PS D:\Workspaces\Sandbox\v6> docker compose exec -T db psql -U cde_admin -d cde_db -P pager=off -c "SELECT column_name, data_type FROM information_schema.columns WHERE table_name='transactions' ORDER BY ordinal_position;"
column_name | data_type
-----+-----
tx_id | bigint
customer_id | bigint
tx_amount | numeric
authorization_status | character varying
masked_pan | character varying
card_token | text
encrypted_chd | text
vault_key_version | integer
tx_timestamp | timestamp with time zone
(9 rows)

PS D:\Workspaces\Sandbox\v6>
PS D:\Workspaces\Sandbox\v6> Write-Host "`n=== CVV/SAD COLUMN CHECK ==="

=== CVV/SAD COLUMN CHECK ===
PS D:\Workspaces\Sandbox\v6> docker compose exec -T db psql -U cde_admin -d cde_db -At -c "SELECT CASE WHEN COUNT(*)=0 THEN 'PASS: no CVV/CVC/CID/security_code column exists' ELSE 'FAIL: SAD column exists' END FROM information_schema.columns WHERE table_name='transactions' AND lower(column_name) IN ('cvv','cvc','cid','security_code');"
PASS: no CVV/CVC/CID/security_code column exists
PS D:\Workspaces\Sandbox\v6>
```

Challenges

Maintaining consistency between implementation, documentation, and evidence.

1

Allowing required services without weakening CDE segmentation.

2

Troubleshooting firewall, routing, TLS, and service dependencies.

3

Producing valid evidence without overstating PCI DSS compliance.

4

Perspectives

What I Learned

- PCI DSS Scoping and Procedures
- Trust-zone and Least-connectivity Design
- Technical Troubleshooting
- Importance of Repeatable Validation

Future Improvements

- Using Dedicated Firewalls and Switches
- Implement Jumpserver Directly
- Have Full SIEM
- Extends the Knowledge of PCI DSS



References

- [1] B. Williams and J. Adamson, PCI Compliance: Understand and Implement Effective PCI Data Security Standard Compliance. Boca Raton, FL, USA: CRC Press, 2022.
- [2] R. Devabhaktuni and G. Venkatasubbu, "Enclave Driven Tokenization: Reducing PCI DSS Scope in Cloud Native Checkout Systems," in Proc. IEEE 5th Int. Conf. AI in Cybersecurity (ICAIC), Houston, TX, USA, 2026, pp. 1–6, doi: 10.1109/ICAIC67076.2026.11395784.
- [3] J. Rees, "Tackling the PCI DSS challenges," Network Security, vol. 2012, no. 1, pp. 15–17, 2012, doi: 10.1016/S1361-3723(12)70009-X.
- [4] N. Mhaskar, M. Alabbad, and R. Khedri, "A Formal Approach to Network Segmentation," Computers & Security, vol. 102, p. 102162, 2021, doi: 10.1016/j.cose.2020.102162
- [5] V. Gil Laredo, "PCI DSS compliance: a matter of strategy," Computer Fraud & Security, vol. 2008, no. 4, pp. 9–12, 2008, doi: 10.1016/S0965-2590(08)70094-X.
- [6] C. Wang and W. P. Rey, "Securing Retail Payments: A PCI-DSS Compliant Network Design for Distributed Point-of-Sale Systems," in Proc. 11th Int. Conf. Communication and Information Processing (ICCIP '25), New York, NY, USA: ACM, 2026, pp. 584–591, doi: 10.1145/3784833.3784909.
- [7] K. Bhargavan, C. Fournet, M. Kohlweiss, A. Pironti, and P.-Y. Strub, "Implementing TLS with Verified Cryptographic Security," in Proc. IEEE Symposium on Security and Privacy (SP '13), Berkeley, CA, USA, 2013, pp. 445–459, doi: 10.1109/SP.2013.37.
- [8] W. Reese, "Nginx: the high-performance web server and reverse proxy," Linux Journal, vol. 2008, no. 173, Art. no. 2, Sep. 2008.
- [9] D. Deeths and G. Brunette, "Using NTP to Control and Synchronize System Clocks - Part I: Introduction to NTP," Sun Microsystems, Tech. Rep., 2001.
- [10] PCI Security Standards Council, "Payment Card Industry (PCI) Data Security Standard: Requirements and Testing Procedures," Ver. 4.0.1, 2024.
- [11] PCI Security Standards Council, "PCI DSS v4.x Quick Reference Guide," 2025.
- [12] PCI Security Standards Council, "Guidance for PCI DSS Scoping and Network Segmentation," 2017.
- [13] LBMC, "Qualities of Good Network Diagrams for PCI," White Paper, n.d.



THANK
YOU!



“Q & A”